

Business Resilience - In-Class Assignment

By: Melvin Viado, Tim Loudon, Daniel Lindo

MGMT 1216: Security Auditing and Governance

Jerrard Gaertner

Durham College

April 10, 2026

Case

"A user in the HR department receives an e-mail with an attachment from someone claiming to be a new hire. The e-mail was from a sender not in the company address book. The subject of the e-mail was "New Hire Forms". The HR employee opens the e-mail and immediately all of their files become encrypted. They phone the service desk asking for help."

Business Resilience Phases

Phase 1 - Preparation

- Routine quarterly staff training sessions should be implemented so that staff at all company levels understand to be wary of emails outside the company address book, especially with clicking on unvalidated attachments. Naturally, all emails outside the company should be treated as suspicious.
- Antivirus would be installed on all staff computers that are industry standard (though this does not account for zero day exploits)
- In the event that an email is received from an unknown address outside the company, it should be immediately flagged, not matter how innocent it appears to be
- Our IT department should have experience, such as SOC analysts, and all emails originating outside the company should be redirected from staff to be analyzed for safety and flagged as potentially dangerous/compromising to company resources
- Before this event occurs, steps should have been taken to incorporate a list of email addresses to deny, along with firewall rules for the email system. Additionally, file extensions within the email should be blocked, especially in the case of automatic malware execution, along with blocking known IP Addresses, domains and URLs that are known to be malicious.
- The majority of these tasks should be addressed with proper preparation and staff training.

Phase 2 - Detection and Analysis

- After the files on the system have been encrypted, steps need to be taken to ensure that the malicious actor does not gain more access to the company's systems and protect any forensic evidence for an investigation.
- Assuming that there is proper logging in place and is being reported through an EDR or similar, the SOC team should begin reviewing logs to try and determine the origin of the attacker and identify scripts used to install the malware on the employee's computer.
- SOC team should be sent samples of the malware for investigative purposes in an isolated test environment in order to understand how it works and try to glean any information about the attacker from it.
- Other systems in the network should be under more scrutiny to detect if the attacker is attempting to move laterally and infect more devices with the ransomware. In this case those devices should be taken off the network as well and analyzed.

Phase 3 - Containment, Eradication, Recovery

Decision criteria that will trigger containment:

- Whether encryption can be confirmed by visible alteration of files or ransom note
- Anomalous email traits such as emails not in address book
- User unable to access files after opening the email attachment

The process of containment should be initiated once the malicious activity can be identified and confirmed. The main activities include stopping the attack from further damage and limiting the spread of the attack. The following is the containment strategy for this email phishing attack that can be executed immediately without manager approval:

- Remove the device of the user from the network to prevent further spread of encryption
- Isolate (lock) the compromised account
- Revoke the active session of the account
- Force password reset
- Blocking the domain that the malicious email was received from
- Notify the Cyber Incident Response Team (CIRT) or IT security lead with initial details including information about the user affected, time of the attack, and symptoms of the attack.

Eradication activities involve removing the threat from the environment and investigating the root cause of the attack. The following involves methods to remove attacker access, clean up attacker persistence, and prevent the attacker from re-establishing access:

- Delete or remove malicious emails
- Removing unauthorized inbox or forwarding rules
- Scan affected systems for malware
- Close any existing entry points
- Patching weaknesses that enabled the attack

Recovery activities that should restore normal business operations safely only after containment and eradication:

- Validating accounts
- Validating email flow
- Restoring affected systems
- Further monitoring for suspicious activity
- Informing impacted users password reset
- Informing users about post-attack instructions

Phase 4 - Post Incident Activity

- After the incident has been resolved and operations have resumed as normal, a timeline of events for the incident should be compiled and submitted to members of the IR team for review and to come up with any further actions that need to be taken
- If an EDR was installed on the employee's computer, all forensic data from the time of the ransomware attack should be compiled and added to the report

- Members of the IR team including anyone that was part of handling the incident should meet together to discuss the steps taken and what can be done to make similar incidents be handled more efficiently
- New employee training should be devised to mitigate any future incidents both ransomware related and otherwise

Specific Considerations

- The employee calling the help desk and the discovery of the encrypted files on their computer (ransomware) is what triggered the event
- Training that should be given to ensure that when any suspicious event occurs on the computers, they should call the help desk for assistance. It is then up to the help desk employees to be trained to recognize what is going on and contact the IRT if necessary
- The process to activate the IRT starts with the help desk employee reaching out to their manager (who should be a member of the team) saying that they believe there has been an incident. The manager then collects all the information to determine if an incident has truly occurred and informs the rest of the IRT of the scenario. The steps of the IR plan are then followed until the incident has been resolved
- Procedures taken during the IR team's investigation should follow their playbook and follow detection and analysis, containment, eradication, recovery, and reviewing what happened to improve the IR plan for future incidents
- Evidence is protected and stored securely by maintaining a record of what occurred over the course of the incident including a timeline of events, system logs, reports generated from EDR/SIEM applications, a record of steps taken to contain and eradicate the malware, and recover from the incident
- IRT members are appointed based on their role in the company including members from senior management, SOC team members, help desk, system administrators, legal teams, and HR staff
- The IR team falls under the information security category

References

Phishing Guidance: Stopping the Attack Cycle at Phase One (PHISHING GUIDANCE: STOPPING THE ATTACK CYCLE AT PHASE ONE TLP:CLEAR - page 7 of the PDF)

<https://www.cyber.gc.ca/en/guidance/ransomware-how-prevent-and-recover-itsap00099>

<https://www.cisa.gov/stopransomware/ive-been-hit-ransomware>

<https://www.microsoft.com/en-us/security/business/security-101/what-is-edr-endpoint-detection-response>

<https://www.cyber.gc.ca/en/guidance/developing-your-incident-response-plan-itsap40003>

<https://sublime.security/articles/phishing-incident-response/#essential-phishing-incident-response-steps>

<https://www.cyber.gc.ca/en/guidance/developing-your-incident-response-plan-itsap40003>